



IT Applications:

Electronic media in business and commerce

Basic concepts of security and trust

Dariusz Caban
dariusz.caban@pwr.edu.pl





Security

- Computer is secure if user can trust it, and the installed software performs according to specification
- Network is secure if it ensures privacy and trustworthiness of the data
- Security depends on
 - Investments into secure technology
 - But even more on human behaviour
 - Majority of incidents utilizes human errors
- Security of web transactions
 - Security of infrastructure (network, server and client workstation)
 - Software security
 - Network communication security



**Weakest
link**



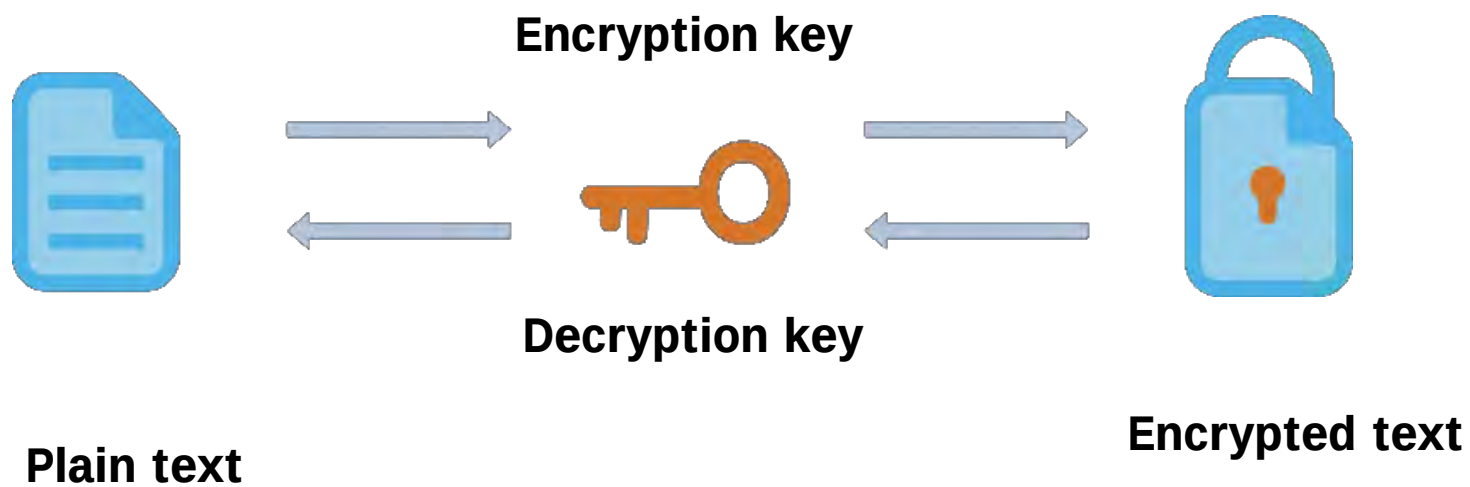


Threats

- Common (not necessarily web based)
 - Data corruption/loss (secure backups)
 - Privacy / data disclosure
 - Unauthorized operations
- Computer with network/Internet access
 - Increased risk of external attacks
 - Anonymous attacks
 - Limited legal protection (jurisdiction)
 - Additional threats
- Transactions in the web
 - Credibility of the order
 - Non-repudiation of the order (irrefutability)
 - Protection of data entrusted by the user



Encryption



Ciphers



Symmetric key ciphers (bulk)

- Single key for encryption and decryption
- Numerical complexity
 - Can be used in real-time
- Encryption – knowledge of plain text and encrypted text is insufficient to determine the key(s)
- Key is not equivalent to password – it is fixed size, much longer
64 – 256 bits

Public key ciphers

- Separate keys for encryption and decryption
- No algorithm for deriving the private key based on public one
 - Numerically complex encryption and decryption
1024 – 2048 bits





Cipher security

- Breaking a cipher
 - Disclosure of secret/private key
- Brute-force attack (exhaustive key search)
 - Based on testing all the key bit permutations (key candidates)
 - Exponential complexity dependent on key size
- Max time needed to break the cipher
$$t = \tau \times 2^l$$
 - l - key length(symmetrical/private)
 - τ - time of a single key computation
- Measured in computational “years”
 - For $l=128$ bits,
 - Number of permutations: $2^{128} \approx 2.56 \times 10^{38}$.
 - If $\tau=1 \mu s$, it requires 10^{25} years.





Cryptoanalysis

- Looks for weaknesses in the ciphers
- Is it possible to reduce the number key candidates?
- Classification of cryptoanalysis methods:
 - Without knowledge of plain text
 - With known plain text
 - Requiring choice of the plain text
 - Requiring dynamic modification of plain text
 - With choice of the encrypted text
 - With dynamic modification of the encrypted text





Bulk ciphers

- Stream ciphers
 - Data is XORed with a pseudo-random bit stream
 - Verman single pass cipher
 - Recently still used – RC4
 - Problem with sufficiently secure random number generators
- Block ciphers
 - Input stream split into fixed size blocks
 - Blocks are independently encrypted
 - Using the same cipher and secret key
 - AES – currently adopted standard



Encryption with block ciphers



Original



Encrypted - ECB

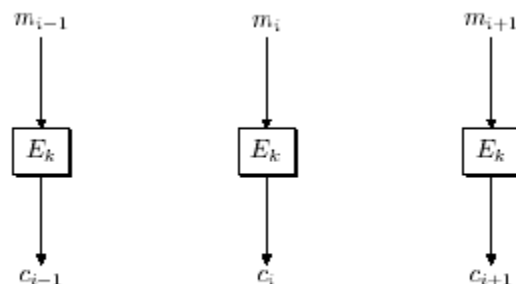


Encrypted - CBC



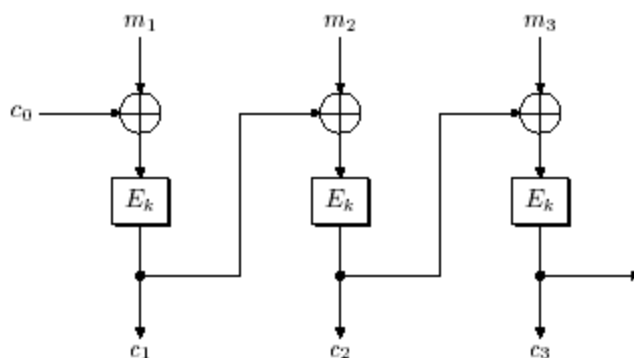


Modes of operation (DES)

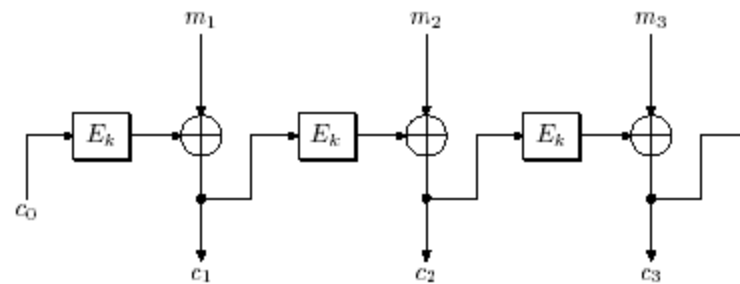


$$c_i = E_k(m_i) \quad m_i = D_k(c_i)$$

Electronic Code Book

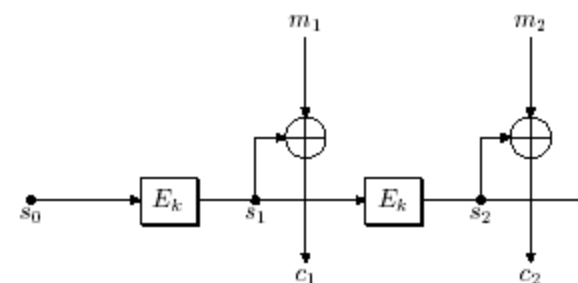


$$c_i = E_k(c_{i-1} \oplus m_i) \quad m_i = c_{i-1} \oplus D_k(c_i)$$



$$c_i = E_k(c_{i-1}) \oplus m_i \quad m_i = E_k(c_{i-1}) \oplus c_i$$

Cipher Feed Back

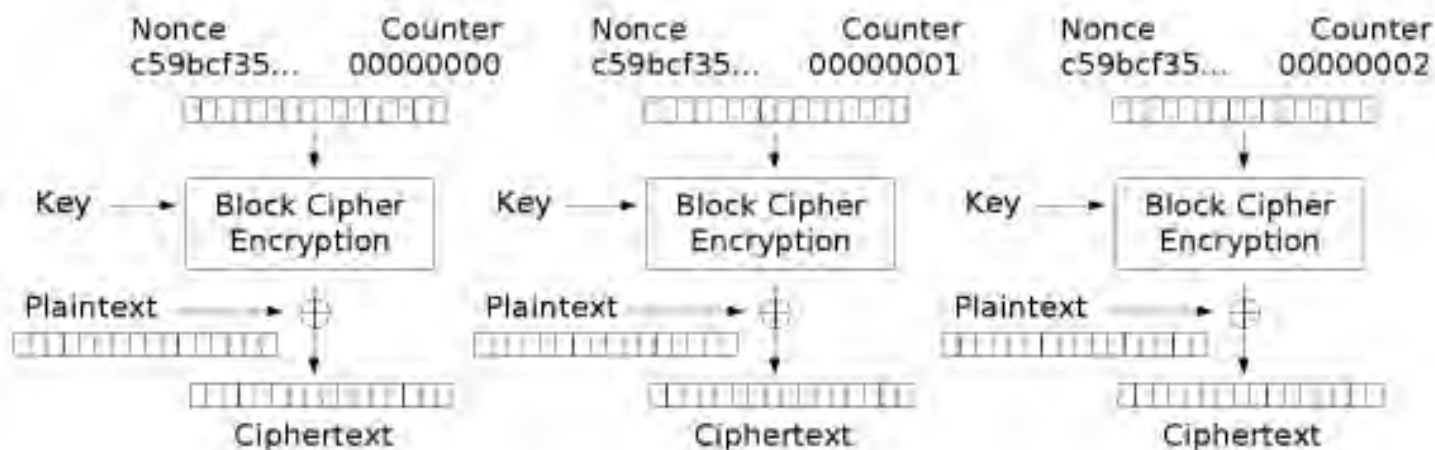


$$c_i = m_i \oplus s_i \quad m_i = c_i \oplus s_i \quad s_i = E_k(s_{i-1})$$

Output Feed Back



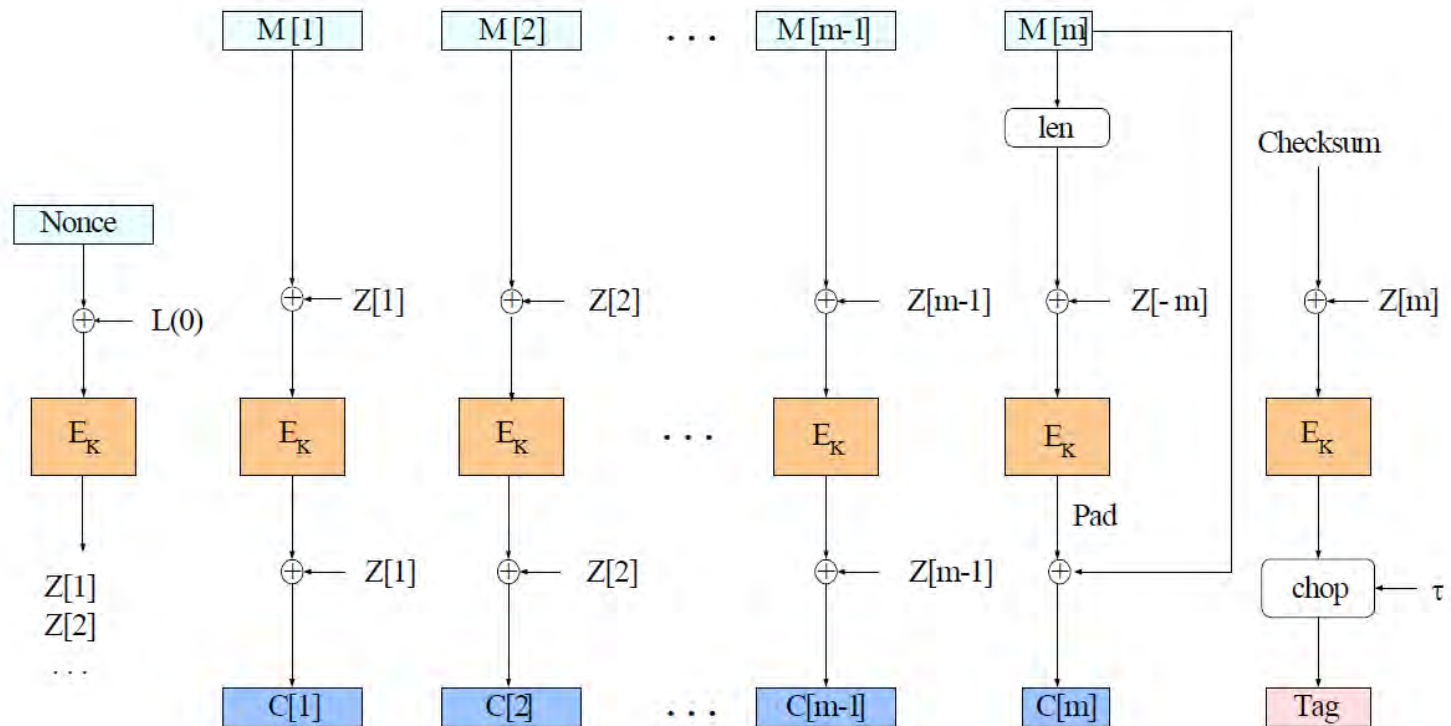
Counter mode encryption – CTR



Counter (CTR) mode encryption



Mode with authentication OCB (Offset Codebook Mode)





Public cryptography

- Based on numerically “difficult” problems
- RSA cryptosystem
 - Multiplicative inverse, prime factoring
- Diffie-Hellman cryptosystem, ElGamal
 - Discrete logarithms
- Cryptographic signature DSA
 - Discrete logarithms
- Public and private keys
 - In RSA public key can be used for encryption or decryption
 - Not so in case of the other cryptosystems





Cipher applications

- Secure data transmission and storage (bulk)
 - Symmetric ciphers
 - Require a common secret (session key)
- Public establishing of a common secret
 - Public key ciphers
 - In data transmission, used for establishing the session key





Cryptographic hash (digest)

- Hashing function
 - Transforms a variable length string of octets (bytes or characters)
 - Into a fixed size digest
- digest = # („text string”)
 - Properties
 - Texts must be uniformly distributed among the digests
 - Slight changes of the text result in unpredictably large changes of the digest
- Secure digest
 - Numerically infeasible to generate a text to satisfy a given digest
 - Digest does not disclose any fragments of the plain text
 - Digests must be relatively long to prevent brute-force attacks
 - Algorithms: MD5, SHA (secure hash algorithm), SHA2, SHA3





Message enveloping

- Building of a letter “in envelop”
 - A random key is generated by the sender (using a random generator) just for this single message
 - The key is used as the secret key to encrypt the plain text letter, using a bulk cipher
 - The secret key is encrypted using a public cryptosystem, using publicly available public key of the message recipient
 - The message is build of the cipher text letter and the encrypted key
- Recipient
 - Decrypts the secret key using his private key
 - Decrypts the letter using a bulk cipher with the decrypted key
- The message sender cannot be authenticated





Digital signature

- Initially used to authenticate electronic mail
 - Or any other electronic document
- Technologically, digital signature is produced by
 - Computing the secure digest of a plain text document
 - Encrypting the digest using the private key of the author (using a public cryptosystem)
- Document recipient verifies the signature by
 - Decrypting the digest using the public key of the author
 - Computing the digest of the plain text document and comparing it with value previously decrypted
- The verification depends on the knowledge of sender's public key
 - The public key is usually extracted from a certificate
 - The certificate is distributed along with the signature





Significance of digital signatures

- Digital signature
 - Ensures authentication of a document, i.e. the identity of the signer (sender)
 - Prevents forgery of the document, i.e. ensures that it cannot be changed without detection
 - Makes the document irrefutable, i.e. the signer (sender) cannot deny its authorship
- Digital signature does NOT
 - Ensure confidentiality (since the document remains plaintext)
 - Prevent spoofing (relies on certificate to prevent spoofing)



Message authentication Code (MAC)



- Prevents data forgery during transmission
- MAC is produced by
 - Computing the secure digest of the message
 - Encrypting the digest using the secret session key
 - SHA1/RC4, MD5/RC2
- HMAC (Hash-based MAC)
 - A simplified version of MAC, not requiring encryption
 - The message and the session key are concatenated
 - The digest is computed from the result
 - Requires a very secure algorithm for computing the digest, so the session key is not compromised
- Digital signature vs. MAC
 - Signatures use public cryptography, MACs use symmetric ciphers
 - MACs do not ensure authentication or irrefutability

